



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



SpiceJet Booking API Passenger Data Exposure Defender Report

Threat Report

Classification	TLP:CLEAR
Published	2026-06-30
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

TLP:CLEAR | Lost Boys Cyber | SpiceJet Booking API Passenger Data Exposure Defender Report - Threat Report

Published: 2026-06-30 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Coverage Window Note
3. Intelligence Requirements
4. Source Review & Confidence
5. Threat Actor / Campaign Overview
6. Tactics, Techniques, and Procedures
7. Infrastructure and Indicators
8. Victimology and Targeting
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypotheses
 - 10.2. Network Hunt Query
11. Risk Assessment
12. Aviation and Aerospace Sector Impact
13. Recommended Actions
14. References

SpiceJet Booking API Passenger Data Exposure Defender Report

1. Executive Summary

CISA published an ICS-style advisory for a SpiceJet online booking system issue involving unauthenticated access to passenger name records through predictable identifiers. Even when an issue is vendor-specific, the pattern is broadly relevant to airlines and travel platforms: booking APIs, PNR workflows, and customer self-service endpoints require authorization and enumeration controls.

2. Coverage Window Note

The aviation/aerospace daily section prioritized the last 24-72 hours first. Because fewer than five corroborated, sector-specific public items were available in that window, this report intentionally expands to a recent/standing sector-relevant source set and labels trend-level or strategic exposure claims accordingly.

3. Intelligence Requirements

Requirement	Answer in This Report
What happened?	Public advisory describes missing authorization on a booking API that could allow PNR enumeration.
Who is affected?	Airlines, booking platforms, travel agencies, and passengers whose data may be exposed through weak API access controls.
What should defenders do?	Audit booking/PNR APIs for authorization, rate limits, and enumeration resistance.
Confidence	High for CISA advisory pattern; scope is product-specific.

4. Source Review & Confidence

Source	Contribution	Confidence
CISA ICSA-26-113-04 SpiceJet Online Booking System	Primary advisory on booking API exposure	High
IATA Aviation Cyber Security	Sector cybersecurity context	Medium
OWASP API Security Top 10	API authorization risk context	High

5. Threat Actor / Campaign Overview

The primary risk is data exposure and trust erosion rather than malware execution. However, exposed passenger/travel data can fuel targeted phishing and social engineering.

6. Tactics, Techniques, and Procedures

Tactic	Technique / Behavior	Defensive Interpretation
Collection	API enumeration of passenger records	Monitor sequential PNR lookup patterns.
Credential/PII Access	Unauthenticated profile data access	Enforce object-level authorization.
Follow-on Social Engineering	Use exposed itinerary data in lures	Alert fraud and customer-care teams.

7. Infrastructure and Indicators

Observable Type	Signal	Notes
Behavior	Source did not publish stable atomic IOCs	Hunt on process, network, identity, and SaaS behaviors.

Hard IOCs are limited where primary sources did not publish stable indicators. Treat behavior, infrastructure class, and telemetry pivots as the primary hunting path until local intelligence enrichment identifies environment-specific indicators.

8. Victimology and Targeting

Airline passengers and the travel platform operator; similar API design flaws can affect other carriers.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Suspicious script or LOLBin execution	Endpoint process telemetry	Surface initial execution and staging activity
New external connection after lure/app execution	Network telemetry	Identify callback or payload retrieval
Unusual account, mailbox, or SaaS activity	Identity/SaaS audit logs	Detect credential abuse and persistence

9.2. Sigma / Detection Rule

```

title: Suspicious Script and Remote Tool Activity - spicejet-booking-api-passenger-data-expo
status: experimental
logsource:
  product: windows
  category: process_creation
detection:
  selection_tools:
    Image|endswith:
      - '\powershell.exe'
      - '\wscript.exe'
      - '\cscript.exe'
      - '\mshta.exe'
      - '\rundll32.exe'
  selection_suspicious:
    CommandLine|contains:
      - 'http'
      - 'download'
      - 'EncodedCommand'
      - 'Invoke-Expression'
  condition: selection_tools and selection_suspicious
level: high

```

9.3. Hunt Query

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where FileName in~ ("powershell.exe", "wscript.exe", "cscript.exe", "mshta.exe", "rundll32.exe",
"node.exe", "osascript")
| where ProcessCommandLine has_any ("http", "download", "EncodedCommand", "Invoke-Expression", "curl",
"wget")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName

```

10. Threat Hunting

10.1. Hunt Hypotheses

Hypothesis	Query Focus
Initial access used lure-driven script, package, or web exploitation behavior.	Correlate suspicious process launches with browser, archive, package-manager, or web-server parents.
Follow-on access used identity or remote-management tooling.	Review new OAuth grants, administrative changes, RMM agents, and rare remote endpoints.

10.2. Network Hunt Query

<pre>DeviceNetworkEvents where Timestamp > ago(14d) where InitiatingProcessFileName has_any ("powershell.exe", "node.exe", "python.exe", "osascript", "curl", "wget") summarize Connections=count(), RemoteUrls=make_set(RemoteUrl, 20) by DeviceName, InitiatingProcessFileName, RemoteIP order by Connections desc</pre>

11. Risk Assessment

Risk Area	Assessment	Rationale
Initial Access	Elevated	Recent reporting indicates active or plausible attacker interest.
Credential Exposure	Medium-High	Many campaigns convert endpoint access into identity abuse.
Operational Disruption	Medium	Impact depends on privilege, sector, and dependency concentration.

12. Aviation and Aerospace Sector Impact

Sector Segment	Operational Relevance	Exposure Path	Defender Action
Airline reservation systems	Passenger data and operational trust	PNR/API enumeration	Object-level authorization, rate limiting, API anomaly detection
Airports/travel partners	Shared itinerary data crosses partners	Partner API integrations	Contractual security review and logging
Fraud/customer care	Exposed travel data enables convincing scams	Phishing/social engineering	Customer notification playbooks and fraud monitoring

Aviation/aerospace operators should assess not only direct enterprise compromise but also third-party concentration: airport common-use platforms, MRO vendors, satellite connectivity providers, identity providers, reservation systems, engineering PLM, and managed service providers can all become operational chokepoints.

13. Recommended Actions

Priority	Owner	Action
High	SOC	Deploy hunts in this report and tune to local telemetry.
High	IT/security engineering	Patch exposed systems, verify EDR

		coverage, and restrict script interpreters where possible.
Medium	Identity team	Review new privileged accounts, OAuth grants, and risky sign-ins for the lookback period.
Medium	Threat intel	Track source updates for IOCs, exploit details, and sector-specific victimology.

14. References

- [1] CISA ICSA-26-113-04 SpiceJet Online Booking System — <https://www.cisa.gov/news-events/ics-advisories/icsa-26-113-04>
- [2] IATA Aviation Cyber Security — <https://www.iata.org/en/programs/security/cyber-security/>
- [3] OWASP API Security Top 10 — <https://owasp.org/API-Security/editions/2023/en/0xa1-broken-object-level-authorization/>